

Informe Técnico de Amenaza: SyslogStealer

Augusto Fuenzalida

Julio 2026

1. Nombre y Descripción de la Amenaza

Nombre: SyslogStealer **Familia:** Keylogger / Spyware **Severidad:** Alta

SyslogStealer es un keylogger para Linux que captura todas las pulsaciones de teclado de la víctima y las transmite cifradas a un servidor de comando y control (C2). Se disfraza como el servicio `syslog-cache.service` de `systemd` para evadir inspección manual y establece persistencia a nivel de usuario sin requerir privilegios root. Implementa:

- Cifrado **AES-256-GCM** (autenticado) con derivación de clave via **PBKDF2-HMAC-SHA256** (200.000 iteraciones).
- Buffer local cifrado en disco: si la conexión al C2 falla, los datos se preservan y retransmiten en el próximo ciclo.
- Envío periódico configurable (por defecto: 30 segundos) y metadata contextual (hostname, timestamp).

2. Vector de Infección y Sistema Operativo Objetivo

SO Objetivo: Primario Linux (con `systemd`) y sesiones X11/XWayland. (Incompatible con Wayland puro).

Vectores Probables: Phishing con adjunto disfrazado; Supply chain/typosquatting; Descarga directa (drive-by); Acceso físico/SSH; Post-explotación.

Flujo de Infección: 1) Ejecución del binario. 2) Instalación en `~/.config/systemd/user/syslog-cache.service`. 3) Activación del servicio. 4) Inicio de captura de teclado. 5) Envío cifrado periódico al C2.

3. TTPs según MITRE ATT&CK

- **T1056.001 (Keylogging) / T1552.001 (Unsecured Creds):** Uso de `pynput` para capturar teclas y credenciales.
- **T1543.001 (Launch Daemon) / T1053.003 (Cron):** Persistencia vía `systemd` de usuario (o `crontab` como fallback).
- **T1027 (Obfuscated Files) / T1036.004 (Masquerading):** Binario compilado y servicio `syslog-cache`.
- **T1022 (Data Encrypted):** Keystrokes cifrados con AES-256-GCM localmente y en tránsito.
- **T1041 (Exfil Over C2) / T1071.001 (App Layer Protocol):** Exfiltración vía protocolo custom TCP.
- **T1082 (System Info):** Registro de hostname y timestamp en la carga útil.

4. Indicadores de Compromiso (IoCs)

Hashes del Binario: (*Reemplazar tras compilar con `build.sh`*)

- **MD5:** [Pegar Hash MD5 aquí] **SHA-256:** [Pegar Hash SHA-256 aquí]

Archivos/Rutas de Interés: `~/.config/systemd/user/syslog-cache.service`, `~/.local/share/.syslog-cache`, `~/.local/share/.syslog-cache/.kb_sent.log`, `/tmp/.syslogd.pid`.

Red: Tráfico TCP saliente al puerto 9999. Ráfagas periódicas (cada ~30s) de blobs cifrados.

5. Impacto Potencial y Mitigación

Impacto: Crítico en Confidencialidad (robo de contraseñas, tokens y correos privados). **Bajo** en Integridad y Disponibilidad (el malware es pasivo).

Mitigación para Usuarios: Mantener el SO actualizado, no ejecutar binarios dudosos, usar gestores de contraseñas y revisar servicios con `systemctl --user list-units`.

Mitigación TI: EDR monitoreando accesos anómalos a `/dev/input`, IDS configurado para detectar conexiones TCP anómalas a puertos no estándar, y uso de reglas YARA para escaneo de binarios.

Regla YARA de Ejemplo:

```
rule SyslogStealer_Keylogger {
  strings:
    $s1 = "syslog-cache" ascii
    $s2 = "PBKDF2HMAC" ascii
    $s3 = "pynput" ascii
    $s4 = ".kb_buf.enc" ascii
  condition:
    2 of them
}
```

6. Análisis de VirusTotal y Evasión (Ejercicio 3)

Al subir el ejecutable `syslog-cache` (16.02 MB) a VirusTotal, se obtuvo una tasa de detección extremadamente baja, confirmando la efectividad de la ofuscación básica utilizada (`--strip` y `--noup` en PyInstaller).

Detección por Firma: Baja (el binario es generado localmente y no tiene hash registrado).

Detección Heurística/Comportamiento: Evadida en su mayoría al no utilizar UPX, lo que evita banderas rojas en el análisis estático de 61 de los 62 motores.

Tasa de detección obtenida: 1 / 62 **Única detección:** Microsoft (PUA:Win32/Puwaders.C!ml)

7. Conclusión

SyslogStealer demuestra cómo un keylogger moderno puede combinar persistencia sin privilegios, cifrado robusto (AES-256-GCM) y ofuscación para comprometer la confidencialidad de un sistema Linux. Su fortaleza radica en que los datos capturados son inútiles al ser interceptados sin la clave derivada en origen. La detección requiere obligatoriamente una estrategia multicapa que involucre EDR, análisis de red y educación del usuario.